INFORMATION SECURITY

송승찬



먼저 뚫어 보고,
숫자로 증명하고,
어디부터 막을지 가려냅니다.

시스템 해킹으로 공격자의 방식을 익히고, AI(RAG) 서비스에서 개인정보가 어디서 얼마나 새는지 재현하고 측정하는 진단 도구 RAG-DIAG를 만들었습니다. 개인정보 보호와 보안 서비스·전략을 감이 아닌 근거와 수치로 기획하는 일을 하고 싶습니다.

학력	세종대학교 정보보호학과 2027.02 졸업 예정 · 학점 4.10 / 4.5 · 130학점	이메일	chanchan3314@naver.com
자격 · 어학	정보보안기사 · TOEIC 850 · OPIc IH	전화	010-7406-3317
프로그래밍 언어	Python 주력 · C	생년월일	2001.01.04
외국어	English 능숙 · 中文 중급	GitHub	github.com/seungchan-song

3등 장려상
캡스톤 경진대회 (RAG-DIAG)

특허 출원 1건
2026.08.31 출원 · 심사 대기 (등록 전)

Elite 3 우수수료
빡공팟 시스템 해킹 트랙 · 수료시험 TOP 3

ABOUT

세 가지로 저를 설명합니다

01

측정하는 사람

위험을 감으로 말하지 않고 지표로 증명합니다. RAG-DIAG에서 위험도 산정식과 대조군 증분 측정, 그리고 한국형 개인정보(PII) 4단계 탐지 파이프라인을 설계했습니다.

02

깊게 배우는 사람

코딩 경험 없이 세종대학교 정보보호학과에 입학해 학과 수석, 빡공팟 시스템 해킹 트랙 Elite Top 3, 정보보안기사를 차례로 이뤄냈습니다.

03

팀을 움직이는 사람

캡스톤과 UBC 해커톤에서 팀 리더를 맡았습니다. 중국 국제학교에서 5년 반을 보내 영어로 협업하는 데 익숙하고, 중국어는 중급 수준으로 UBC에서 중국인 팀원과 소통하는 데 썼습니다.

FEATURED PROJECT

RAG-DIAG
RAG 개인정보 유출 취약점 진단 CLI

팀장 · 4인 팀 | 세종대 캡스톤 디자인 | 2026.03 – 2026.09 | MIT License

GitHub ↗ | PII 탐지 모델 ↗ | 교차검증 sLLM ↗ | 합성 데이터셋 ↗

MY ROLE

팀장으로 4인 팀을 이끌며, 진단의 판단 기준을 설계했습니다.

01 팀장
회의를 운영하고, 회의마다 팀원의 역할에 맞는 과제를 주고 피드백했습니다.

02 한국형 PII 탐지 파이프라인 설계
4단계 구조와 판정 기준을 정했습니다.

03 위험도 산정식 · 대조군 증분 실험 설계
공격이 만든 유출만 따로 재는 방식을 만들었습니다.

04 문서화 총괄
요구사항 분석서, 프로젝트 설계서, 최종 보고서, 특허 문서 4종의 작성을 총괄했습니다.

PROBLEM

RAG는 LLM 환각을 줄이는 실무 표준이 되었지만, 외부 지식베이스와 검색 단계가 더해지며 **검색 데이터 유출 · 멤버십 추론 · 시스템 프롬프트 유출 · 간접 프롬프트 주입**이라는 새 공격 표면이 생겼습니다. 한국어 환경에서는 13자리 숫자가 체크섬을 통과해야 주민등록번호이고, '하늘'이 이름인지 일반 단어인지는 문맥으로만 구분됩니다. 이런 한국형 개인정보 판정까지 포함해 위험을 정량 진단하는 도구가 필요했습니다.

APPROACH

한 줄 요약 · 공격 질문을 RAG에 던지고, 돌아온 답변에서 개인정보가 얼마나 새었는지 점수로 매깁니다.

STEP 1 질문 던지기

- R2 검색 데이터 유출
- R4 멤버십 추론
- R7 시스템 프롬프트 노출
- R9 간접 프롬프트 주입

대조군 공격 없이 평범하게 묻는 질문입니다. 비교 기준으로 함께 던집니다.

→

STEP 2 진단 대상 RAG가 답하기

문서를 색인해 만든 RAG가 공격 질문과 대조군 질문에 모두 답합니다. 모델 · Top-k · 리랭커 설정은 바꿔 가며 진단합니다.

Haystack v2 | FAISS | BGE-m3-ko | Qwen2.5-3B · Ollama

→

STEP 3 개인정보 찾아 점수 매기기

- 탐지 정규식 › 체크섬 › NER › sLLM
- 점수 성공률 50% + 강도 50%
- 비교 대조군 대비 증가분
- 출력 HTML · CSV · JSON

전 과정이 로컬 모델로 돌아가 폐쇄망에서도 쓸 수 있습니다. 실행 ID · 설정 스냅샷 · 문서 해시를 남겨 중단 재개와 동일 조건 재실행도 됩니다.

RESULT

어떤 조건에서 얻은 결과인가

대상	**RAG-DIAG에 내장된 RAG** · Haystack v2 · FAISS · Qwen2.5-3B (Ollama로 로컬 실행)
데이터	**합성 문서**에 **가짜** 개인정보(주민번호 · 카드 · 계좌 · 연락처)를 심었습니다. 실제 개인정보는 쓰지 않았습니다.
실험	**공격 4종 + 대조군** · 질문 988개 · 리랭커 켬/끔 비교 · 2026.08.14 실행, 실패 0건

그래서 무엇을 알았나

Q1 가장 위험한 공격은?

자주 뚫리는 공격과 치명적인 공격은 다릅니다.

공격마다 성공률과 뚫렸을 때의 깊이(강도)를 합쳐 100점으로 매겼습니다. 시스템 프롬프트 노출은 성공률이 15.0%로 가장 낮았지만, 뚫리면 방어 규칙의 83%가 드러나 위험도 1위였습니다.

근거
위험도(100점) 시스템 프롬프트 노출 49 · 멤버십 추론 40 · 간접 주입 39 · 검색 데이터 유출 37

Q2 공격이 평범한 질문보다 더 새게 했나?

공격이 만든 유출은, 대조군이 있어야 보입니다.

질문 수를 맞춰 비교하니, 검색 데이터 유출 공격은 평범한 질문(대조군)보다 주민번호 · 카드 · 계좌 같은 정보를 2배 더 새게 했습니다. 대조군이 없으면 원래 새던 양과 공격이 늘린 양을 가를 수 없습니다.

근거
고유식별 · 금융 정보 노출 대조군 27건 → 공격 54건

Q3 방어 장치를 켜면 안전해지나?

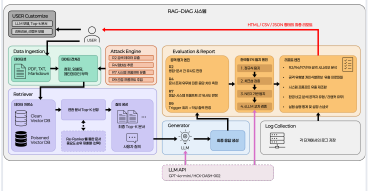
한 공격을 막는 방어가, 다른 공격에는 불리할 수 있습니다.

리랭커(검색 결과를 다시 걸러 주는 장치)를 켜자 검색 데이터 유출은 줄었지만, 멤버십 추론은 오히려 늘었습니다. 방어 수단은 도입 전에 내 환경에서 직접 재봐야 합니다.

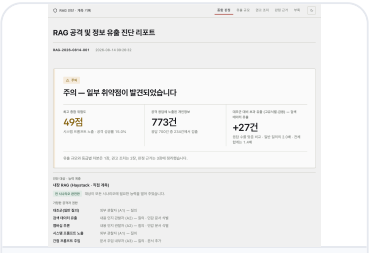
근거
리랭커 끔 → 켬, 공격 성공 건수 검색 데이터 유출 37 → 12 · 멤버십 추론 15 → 46

품질 검증 · 회귀 테스트 443건 전량 통과 · PII 탐지 재현율 94.5% · 정밀도 79.7% (합성 홀드아웃 문서 1,320건 기준)

실제 화면



시스템 구조도



진단 리포트 화면



CLI 실행 화면

OUTCOME

수상	**캡스톤 경진대회 장려상 (3등)**
특허	**특허 출원 1건** · 「검색 증강 생성 환경에서의 정보 유출 취약점 진단 시스템 및 방법」 출원번호 10-2026-0164171 · 2026.08.31 출원 · 심사 대기(등록 전) · 출원인 세종대학교산학협력단
대회	**2026 오픈소스 개발자대회 학생부 출품**
공개	**오픈소스 공개** · 코드(MIT License)와 PII 탐지 모델 · 교차검증 sLLM · 합성 데이터셋을 GitHub와 Hugging Face에 공개

OTHER WORK

그 밖의 활동

SYSTEM HACKING

빡공팟 시스템 해킹 트랙

2025.06.09 – 2025.08.31

수료시험 TOP 3 (Elite 3). 수료율 31.8%의 서바이벌 과정에서 수료시험 상위 3명에게 주는 Elite 3 우수 수료를 받았습니다. 메모리 취약점 공략부터 SROP 등 보호기법 우회까지 직접 재현했습니다. 리눅스 지식 없이 시작해 초반 과제를 끝내지 못해 탈락 위기였지만, 개념 사이의 연결을 먼저 정리하고 실습으로 재현하는 방식으로 공부법을 바꾼 뒤 수료시험에서 3위 안에 들었습니다.

BLOCKCHAIN · HACKATHON

UBC 블록체인 연수 · Health Access Registry

2026.08.16 – 2026.08.30

해커톤 3등, 팀 리더. 스위스·중국 팀원과 함께 환자 의료기록의 접근 권한과 접근 기록을 온체인으로 관리하는 시스템을 설계했습니다. 블록체인에는 환자 데이터를 두지 않고 누가 접근 가능했고 누가 시도했는지만 남깁니다.

GitHub ↗

PYTHON · TEAM LEAD

보이스피싱 레이더

2026.09.21 – 2026.10.02

SK쉴더스 루키즈 35기 팀 프로젝트, 6인 팀의 팀장. 경찰청 공공 통계와 뉴스를 결합해 피해 현황과 최신 수법을 분석하고, 웹 대시보드·경보 메일·Notion 기록으로 보여주는 시스템입니다. 저는 공통 코드와 Flask 웹 개발, 통합과 저장소 관리를 맡았습니다.

GitHub ↗

SKILLS

사용해 본 언어와 도구

프로젝트와 수업, 실습에서 실제로 써 본 것만 적었습니다.

프로그래밍 언어

주력
Python
RAG-DIAG · 보이스피싱 레이더

C
시스템 해킹 실습 · 전공 수업

외국어

능숙
English
TOEIC 850 · OPIc IH · 중국 국제학교 5년 반 · UBC 영어 협업

중급
中文
영어와는 격차가 있습니다. 중국 생활 경험 · UBC에서 중국인 팀원과 소통

도구 · 기술

RAG · LLM

Haystack v2 · FAISS · Ollama · Qwen2.5-3B · BGE-m3-ko · Hugging Face · KPF-BERT (NER)

RAG-DIAG

웹 · 데이터 · 협업

Flask · pandas · matplotlib · BeautifulSoup · MongoDB Atlas · Notion API · Typer · Rich (CLI) · Git · GitHub · Notion

보이스피싱 레이더 · RAG-DIAG

보안 · 시스템

Linux · 메모리 취약점 공략 · SROP · Proxmox · Docker · QEMU · 디지털 포렌식 (FTK Imager · HxD)

빡공팟 · 전공 실습

블록체인

Ethereum (Sepolia) · MetaMask

UBC 해커톤 (Health Access Registry)

PROFILE

학력 · 교육 · 자격 연혁

2017.03 – 2020.02
학력 **상산고등학교**

2021.03
학력 **세종대학교 정보보호학과 입학**
코딩 경험 없이 입학해 파이썬과 C를 병행 학습했습니다.

2023.04 – 2025.01
군 복무 **대한민국 공군 · 대공포 운용**
으뜸병사 · 병사와 간부 사이 소통 중재 (약 60명, 6개월)

2025.06.09 – 2025.08.31
교육·연수 **빡공팟(P4C) 13기 시스템 해킹 트랙**
RED 코스 · 수료율 31.8% · 수료시험 TOP 3 · Elite 3 우수수료증

2026.02.28
자격·어학 **TOEIC · 850**
LC 465 · RC 385

2026.08.16 – 2026.08.30
교육·연수 **UBC Blockchain Summer Institute**
캐나다 UBC · 블록체인 기술·규제 연수 · 해커톤 3등(팀 리더)

2026.08.28
자격·어학 **정보보안기사**
국가기술자격

2026.09.27
자격·어학 **OPIc · IH (Intermediate High)**
ACTFL 영어 말하기 평가

2026.09 –
교육·연수 **SK쉴더스 루키즈 35기**
클라우드기반 스마트 융합보안 과정 · 진행 중

2027.02 예정
학력 **세종대학교 정보보호학과 졸업**
4학년 2학기, 마지막 학기 재학 중입니다. 군 복무 후 3학년으로 복학했고, 복학 첫 학기에 학과 수석을 했습니다.

총 취득 **130학점** | 평점 평균 **4.10 / 4.5**

CONTACT

개인정보와 보안 위험을 수치로 설명하는 일, 함께하고 싶습니다.

chanchan3314@naver.com
GitHub ↗
PDF (한국어)
PDF (영문 요약)